INSPECCO × KRIPTARIUM

Safety 4.0 Bootcamp

Laboratuvar Föyleri — PaketPro 3000 Sürümü · Paketleme Makinesi

Tüm laboratuvarlar deck'in işlenmiş örnek makinesi PaketPro 3000'e uyarlanmıştır: sıcak çene + kesme bıçağı · ışık perdesi · 16 varlık + 5 dış bağlantı · internete açık uzak bakım modülü.

LAB 1 · Safety Architecture	Çıktı: Safety Function Map
LAB 2 · IEC 62443 Mini Workshop	Çıktı: Zone / Conduit Diagram
LAB 3 · Threat & Risk + Risk Matrix	Çıktı: Risk Register
LAB 4 · Secure Remote Access	Çıktı: Secure Architecture
LAB 5 · SBOM / CVE / Patch	Çıktı: Vulnerability Decision
LAB 6 · CRA Incident Simulation	Çıktı: Incident Workflow
LAB 7 · AI Safety Challenge	Çıktı: AI Fail-Safe Decision

Bu föyler bir eğitim çıktısıdır; resmî denetim, uygunluk değerlendirmesi veya belgelendirme değildir ve CE/mevzuat uygunluğu garantisi vermez. Doldurduğunuz föyler gün sonunda Machine Starter Pack'inizi oluşturur ve Safety 4.0 Workspace'te yaşamaya devam eder.

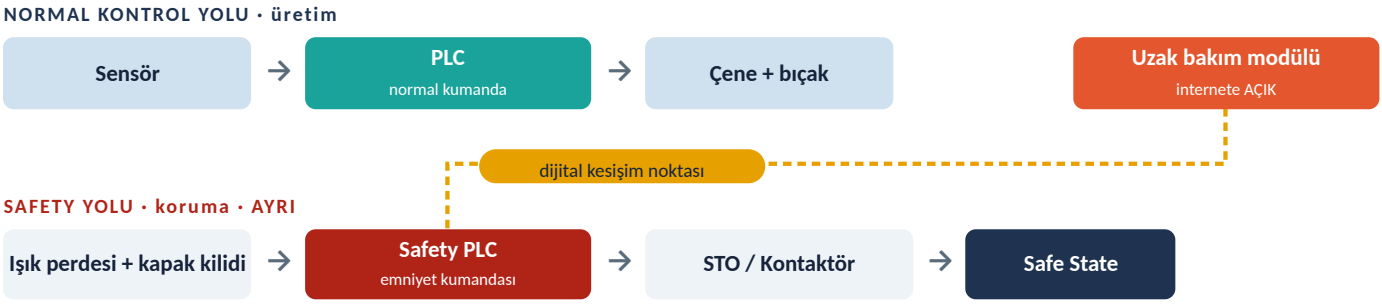
LABORATUVAR 1 · PAKETPRO 3000 · Paketleme Makinesi

Safety Architecture

Çıktı: Safety Function Map

Ad Soyad Mustafa Önler | Grup Gece-B | Tarih

PaketPro bağlamı: Sıcak yapıştırma çenesi ve film kesme bıçağı el/parmak için ciddi tehlikedir; koruma **ışık perdesi + kapak kilidi → Safety PLC → STO** zinciridir. Ve bu makinenin **internete açık bir uzak bakım modülü** vardır — sorular oraya gidecek.



Görev — sırayla cevaplayın

1 Bu makinede tehlike nedir? İnsan neyden zarar görür?

PaketPro 3000 paketleme makinesinde temel tehlike, yüksek sıcaklıkta çalışan **sıcak yapıştırma çenesi** ve yüksek hızla hareket eden **film kesme bıçağıdır**. İnsan (operatör), ambalaj filmini düzeltirken veya hattan ürün müdahalesi yaparken ellerinin ve parmaklarının bu sıcak çene arasında yanması ya da kesme bıçağı tarafından kesilmesi/kopması tehlikesiyle karşı karşıyadır.

2 Safety function (emniyet fonksiyonu) hangisidir?

Emniyet fonksiyonu, operatörün tehlikeli bölgeye erişimini engelleyen veya kapak açıldığında sistemi durduran **"Işık perdesi + kapak kilidi → Safety PLC → STO"** koruma zinciridir.

3 Safety-related control system nerede? Şemada işaretleyin.

Şemadaki alt satırda yer alan **"SAFETY YOLU - koruma - AYRI"** etiketli hattın tamamıdır. İzlediği yol sırasıyla şöyledir: [Işık perdesi + kapak kilidi] → [Safety PLC] → [STO / Kontaktör] → [Safe State]

4 Normal PLC ile Safety PLC farkı nedir?

Normal PLC, paketleme makinesinin üretim hızını, film akışını, çene ısıtma döngülerini ve normal çalışma komutlarını yönetir. Safety PLC ise yalnızca insan güvenliğinden (ışık perdesi ve kapak kilitlerinden gelen sinyallerden) sorumludur. En önemli fark, Safety PLC'nin yedekli (redundant) mimariye sahip olması ve kendi iç teşhisini (self-diagnostic) yaparak arıza anında sistemi güvenli duruma geçirmesidir.

5 PLr / SIL neden var? Bu fonksiyon için neden önemli?

PLr veya SIL, emniyet fonksiyonunun ne kadar güvenilir olması gerektiğini belirten uluslararası standartlardır. Paketleme makinelerinde sıcak çene ve kesici bıçak nedeniyle yanma ve ezilme riski yüksek olduğu için, sistemin yüksek güvenlik seviyesinde tasarlanması; elektronik veya yazılımsal bir arıza durumunda dahi emniyetin devre dışı kalmamasını garanti etmek için hayati önem taşır.

6 Safe state (güvenli durum) nedir?

PaketPro 3000 için "Safe State", STO (Safe Torque Off) veya emniyet kontaktörlerinin devreye girerek hareketli çene motorlarına ve kesme bıçağı aktüatörlerine giden elektrik/güç beslemesini tamamen kesmesi durumudur. Bu durumda tüm mekanizmalar anında durur ve enerjisiz kalarak tehlikesiz duruma geçer.

7 Safety function hangi dijital bağımlılıklara sahip?

Emniyet fonksiyonu, makinenin genel durumunu, hata kodlarını ve emniyet durumunu normal üretim ekranına aktarmak için şemada turuncu kesik çizgilerle gösterilen **"dijital kesişim noktası"** üzerinden Normal PLC ile haberleşir.

8 Siber müdahale hangi noktadan bu fonksiyonu bozar?

Siber müdahale, şemada sağ üstte yer alan ve **internete açık olan uzak bakım modülü** üzerinden sisteme sızan bir saldırganın, dijital kesişim noktası yoluyla Normal PLC ve Safety PLC arasındaki haberleşmeyi manipüle etmesiyle gerçekleşir. Saldırgan bu yolla ışık perdesini veya kapak kilidi denetimini yazılımsal olarak etkisiz hale getirebilir.

Bu föyün çıktısı **Safety Function Map** → Evidence Pack **EP 03 Safety Functions** başlığına oturur.

IEC 62443 Mini Workshop

Çıktı: Zone / Conduit Diagram

Ad Soyad Mustafa Önler | Grup Gece-B | Tarih

Kavram: Zone = benzer kritiklikteki cihazları bir bölgeye topla. **Conduit** = bölgeler arası her geçişe kontrollü bir kapı. 62443'ün maddesini ezberlemiyoruz — mantığını uyguluyoruz.

Görev A — varlıkları bölgelere ayırın

Varlık listesi

Üretim PLC, Emniyet PLC'si, HMI, Motor sürücüleri/Eksenler, İnternete açık uzak bakım modülü, Bulut telemetri, Wi-Fi AP, Kilitsiz USB, Servis hesabı

1 Hangi varlıklar aynı bölgede? Bölgeleri adlandırıp gruplandırın.

Baykal Abkant Pres mimarisinde varlıkları kritiklik düzeylerine göre şu bölgelere (Zone) ayırıyoruz:

- **Bölge 1 (Machine Control / Cell Zone - Hücre Kontrol Bölgesi):** Üretim PLC'si, HMI (dokunmatik CNC ekran) ve eksen motor sürücüleri bu bölgededir. Makinenin anlık büküm ve hidrolik işlemlerini yürütürler.
- **Bölge 2 (Safety Zone - Emniyet Bölgesi):** Emniyet PLC'si (Safety PLC) bu bölgededir. İnsan güvenliğini sağlayan bu kritik donanım, dış ağlardan izole edilmiştir.
- **Bölge 3 (Enterprise / DMZ & Cloud Zone - Kurumsal ve Dış Bağlantı Bölgesi):** İnternete açık uzak bakım modülü, bulut telemetri servisleri, Wi-Fi erişim noktası, kilitsiz USB arayüzleri ve varsayılan servis hesapları bu dış ve riskli grupta yer alır.

2 Açık uzak bakım modülü hangi bölgeye düşüyor — neden? Orada KALABİLİR Mİ? Neden?

- Hangi bölgeye düşüyor ve kalabilir mi?: Açık uzak bakım modülü **Enterprise / Dış Bağlantı Bölgesi'ne** düşer.
- Neden kalmamalı?: Bu modül doğrudan internete açık olduğu ve üzerinde zafiyet barındırabileceği için bu bölgede **asla olduğu gibi (güvencesiz) KALAMAZ**. Doğrudan 7/24 internete açık olması, saldırganların doğrudan makine kontrolüne erişmesine yol açar; bu nedenle arkasına bir Jump Server (Atlama Sunucusu) ve VPN tüneli konulmadan açık bırakılamaz.

3 Bölgeler arası geçişler (conduit) nerede? Her geçişte ne kontrol edilecek?

- **Geçiş 1 (Enterprise / Uzak Bakım ➔ Machine Control Zone / HMI & PLC Köprüsü):** Dış ağ/bakım modülü ile CNC kontrol ünitesi arasındadır. Bu geçişte (Conduit), gelen verinin bütünlüğü, kimlik doğrulaması (MFA) ve zararlı yazılım taranması denetlenir.
- **Geçiş 2 (Machine Control Zone ➔ Safety Zone / Emniyet Kesişimi):** Üretim PLC'si ile Emniyet PLC'si arasındaki haberleşme hattıdır. Bu geçişte, normal üretim yazılımının emniyet parametrelerini manipüle etmesini engelleyen katı protokol filtrelemesi denetlenir.

Görev B — uzak erişim kararı (6 satır)

Karar	Seçenekler	Seçiminiz + nedeni
Aracı?	Doğrudan / Jump server	**Jump Server**. Doğrudan dışarıdan makineye bağlanmak yerine, fabrikadaki ara güvenli atlama sunucusu aracı olarak kullanılır.
Tünel?	Açık / VPN	**VPN**. Açık internet üzerinden yapılan güvensiz bağlantılar yerine uçtan uca şifrelenmiş tünelleme tercih edilir.

Karar	Seçenekler	Seçiminiz + nedeni
Kimlik?	Parola / MFA	**MFA**. Sabit ve zayıf parolalar yerine çok faktörlü kimlik doğrulama zorunlu tutulur.
Hesap?	Paylaşılan / Kişisel	**Kişisel**. Ortak ve varsayılan (admin/admin gibi) servis hesapları kapatılır, her mühendise özel izlenebilir hesap verilir.
Kayıt?	Yok / Tam oturum kaydı	**Tam oturum kaydı**. Uzaktan bakım süresince yapılan tüm CNC ve sistem müdahaleleri eksiksiz olarak kaydedilir.
Zamanlama?	Sürekli açık / Varsayılan kapalı	**Varsayılan kapalı**. Portlar 7/24 açık kalmaz; sadece bakım süresince geçici olarak (Just-In-Time) açılır.

Bu föyün çıktısı **Zone / Conduit Diagram** → Evidence Pack **EP 05 Zone & Conduit** başlığına oturur.

LABORATUVAR 3 · PAKETPRO 3000 · Paketleme Makinesi

Threat & Risk + Risk Matrix

Çıktı: Risk Register

Ad Soyad Mustafa Önler | Grup Gece-B | Tarih

Kavram: Senaryo beş parçadır: **kim → hangi kapı → ne yapar → zincir → FİZİKSEL sonuç**. Skor = L × S × E (her biri 1–3). **Kural:** S=3 ise skor düşük olsa bile senaryo öne alınır — insana zarar görünür kalır.

PaketPro'nun kapıları (ipucu)

İnternete açık uzak bakım modülü · admin/admin hesabı · port 80 HMI · Wi-Fi (karton parola) · 2 kilitsiz USB · bulut telemetri — *fiziksel sonuç adayları: çene/bıçakta el-parmak yaralanması, sıkışma.*

Görev — üç senaryo kurun ve puanlayın

(Formül: Skor = L × S × E [Her biri 1-3] | Kural: S=3 ise skor düşük olsa bile öncelik en yüksektir.)

Senaryo (kim → kapı → ne yapar → zincir → fiziksel sonuç)	L	S	E	Skor	Öncelik
Dış Saldırgan → İnternete Açık Uzak Bakım Modülü (Admin/Admin Parolası) → CNC Lazer Koruma Parametrelerini Değiştirir → Işık Bariyeri Devre Dışı Kalır → Operatörün Elleri Üst Çene Altında Ezilir (Kritik Fiziksel Yaralanma).	2 (Ağ üzerinden erişim riski yüksek)	3 (Ölümcül / Ağır uzuv kaybı)	2 (Vardiya boyunca makine sürekli çalışıyor)	2 × 3 × 2 = 12 (Yüksek / Kritik)	1 (En Yüksek)
Kötü Niyetli İç Personel → Kilitsiz USB / Zayıf Wi-Fi Ağı → Zararlı Script Yükler → Normal PLC Büküm Basıncını ve Hızını Maksimuma Çıkarır → Hidrolik Valf Blokajı / Gövde Patlaması → Saçılan Parçalar Operatöre Şiddetli Darbe Verir.	1 (Fiziksel veya yerel ağ erişimi gerektirir)	3 (Fiziksel yaralanma / travmatik darbe)	1 (Nadir yapılan USB veri yüklemesi)	1 × 3 × 1 = 3 (Düşük Skor)	2 (S=3 kuralı gereği skor düşük olsa da insana zarar vereceği için öne alınır)
Yetkisiz Kullanıcı → Port 80 HMI (Web Arayüzü) → Arka Dayama Eksen (X, R, Z) Koordinatlarını Bozar → Sac Levha Hatası ve Geri Tepme Oluşur → Operatöre Çarparak Travmatik Fiziksel Hasar Oluşturur.	2 (Ağ üzerinden şifresiz HMI erişimi)	2 (Orta düzey fiziksel darbe / ezilme)	2 (Günlük üretim boyunca aktif)	2 × 2 × 2 = 8	3

Kritik 18–27 | Yüksek 9–17 | Orta 4–8 | Düşük 1–3

1. En yüksek öncelikli senaryo hangisi? Bir cümleyle: neden bu?

   En yüksek öncelikli senaryo 1 numaralı senaryodur; çünkü internete açık uzak bakım modülü ve varsayılan zayıf parola (admin/admin) üzerinden sızan bir saldırganın doğrudan lazer koruma bariyerini devre dışı bırakarak S=3 (ölümcül ezilme riski) seviyesinde fiziksel yıkım üretmesi en büyük tehdittir.s

2. S=3 olup skoru düşük kalan senaryonuz var mı? Nasıl görünür kılacaksınız?

   Evet, 2 numaralı senaryoda Olasılık (L=1) ve Maruz Kalma (E=1) düşük olduğu için toplam skor 3 çıkmıştır; ancak Şiddet seviyesi (S=3) insana doğrudan zarar vereceği için kritik risk taşır. Bunu risk matrisinde ve raporda “Düşük Olasılıklı Fakat Felaket Senaryosu (High-Impact Low-Frequency)” olarak etiketleyip rengini kırmızıya çekerek görünür kılacağız.

Altın kural: Zincir "veri çalındı" ile bitiyorsa emniyet bulgusu değildir — bir adım daha gidin: bu, hattaki insana ne yapar?

Bu föyün çıktısı **Risk Register** → Evidence Pack **EP 04 Risk Assessment** başlığına oturur.

LABORATUVAR 4 · PAKETPRO 3000 · Paketleme Makinesi

Secure Remote Access

Çıktı: Secure Architecture

Ad Soyad Mustafa Önler | Grup Gece-B | Tarih

Kavram: İki katman, ikisi de şart: **erişim güvenliği** (girişi zorlaştır: ara nokta, VPN, MFA, kişisel hesap, kayıt, varsayılan kapalı) + **emniyet bağımsızlığı** (girse bile insan korunur).

Görev A — mevcut → hedef

MEVCUT (çizin/yazın)

İpucu: uzak bakım modülü bugün internete DOĞRUDAN açık.

- Makinenin uzak bakım modülü ve CNC kontrol ünitesi bugün internete DOĞRUDAN açıktır.
- Üretici servis mühendisleri sisteme şifresiz portlar ve paylaşılan ortak "admin/admin" parolalarıyla bağlanmaktadır.
- Uzak erişim portları 7/24 aktif ve sürekli açık kalmaktadır; yapılan oturumlar kayıt altına alınmamaktadır.
- Makine ağında herhangi bir segmentasyon veya uç nokta koruma katmanı bulunmamaktadır.

HEDEF (beş ilkeyle yeniden tasarlayın)

1. Erişim Kontrolü ve Aracı: Doğrudan dış bağlantı kaldırılmış, fabrikadaki güvenli bir **Jump Server (Atlama Sunucusu)** aracı olarak konumlandırılmıştır.

2. Güvenli Tünel: Dışarıdan gelen erişimler şifreli **VPN tünelleri** üzerinden sınırlandırılmıştır.

3. Kimlik Doğrulama: Basit parolalar yerine **Çok Faktörlü Kimlik Doğrulama (MFA)** zorunlu kılınmıştır.

4. Hesap Yönetimi: Ortak hesaplar yasaklanmış, her mühendis için **kişisel ve izlenebilir hesaplar** tanımlanmıştır.

5. Zamanlama ve Kayıt: Portlar varsayılan olarak kapalıdır (**Just-In-Time erişim**); tüm uzaktan bakım oturumları eksiksiz olarak **tam oturum kaydına (log)** alınmaktadır.

Görev B — functional safety köprüsü

1 Saldırgan tüm önlemlere rağmen içeri girerse: emniyet fonksiyonu etkilenir mi? Neden?

Evet, etkilenme riski bulunur. Eğer saldırgan Normal PLC veya CNC kontrol ünitesi üzerinden Safety PLC ile kurulan dijital haberleşme köprüsüne sızmayı başarırsa; emniyet parametrelerini değiştirebilir, lazer koruma bariyerlerinin (muting) körleme alanlarını manipüle edebilir veya acil stop sinyallerinin işlenmesini yazılımsal olarak aksatabilir.

2 Işık perdesi zincirinin uzak bakım yolundan etkilenmemesi için GEREKSİNİMİ yazın (çözümü değil).

Gereksinim Tanımı: Işık perdesi ve acil stop mekanizmalarını içeren emniyet zinciri (Safety Function), kurumsal ağdan, internete açık uzak bakım modülünden ve normal üretim kontrol mantığından mantıksal/fiziksel olarak tamamen izole edilmeli; dış ağdan gelebilecek hiçbir komut veya zafiyet, emniyet sisteminin donanımsal ve yazılımsal karar mekanizmasını doğrudan değiştirememelidir (Emniyetin bağımsızlığı ve izolasyonu ilkesi).

Tarafsızlık notu: Bu föy çözüm tasarlatmaz; gereksinimi tanımlatır. Tasarım kararı firmanızındır.

Bu föyün çıktısı **Secure Architecture** → Evidence Pack **EP 02 + EP 06** başlığına oturur.

SBOM / CVE / Patch

Çıktı: Vulnerability Decision

Ad Soyad Mustafa Önler | Grup Gece-B | Tarih

Kavram: SBOM = yazılım malzeme listesi · **CVE** = açığın kayıt no'su · **CVSS** = ciddiyet (0–10). Bir CVE sizi etkiler mi? Üç şart: bileşen **var**, sürüm **etkileniyor**, açık **ulaşılabilir**.

Verilen zafiyet kaydı

Bileşen	PaketPro Component X (PLC firmware kütüphanesi)
Sürüm	2.4
CVE	CVE-XXXX-XXXX
Önem	Critical (CVSS 9.8)
Yama	Mevcut

Görev — karar akışı

1. Bu CVE sizi gerçekten etkiliyor mu? (üç şartı kontrol edin)

   - Bileşen Var mı?: Evet, Baykal APHS Abkant makinesinin CNC kontrol ünitesinde ve PLC firmware altyapısında "PaketPro Component X / PLC firmware kütüphanesi v2.4" muadili olan CNC/PLC kontrol kütüphanesi kullanılmaktadır.
   - Etkileniyor mu?: Evet, yayınlanan zafiyet bildirimi doğrudan v2.4 sürümünü hedeflemektedir.
   - Ulaşılabilir mi?: Evet, makinenin uzak bakım modülü ve fabrika ağı arayüzleri üzerinden dışarıdan ağ erişimine açık olması nedeniyle zafiyet uzaktan sömürülebilir (ulaşılabilirdir).

2. Üretimi hemen durdurur musunuz? Neden / neden değil?

   Hayır, üretimi derhal durdurmayız. Fabrikanın anlık operasyonel kayıp ve maliyet yaşamaması için, öncelikle zafiyetin sömürülme vektörünün ağ seviyesinde (firewall veya izolasyonla) kapatılıp kapatılamayacağına bakılır. Planlı bir bakım penceresi oluşturulana kadar geçici telafi edici önlemler devreye sokulur; acil duruş yalnızca aktif bir siber saldırı tespit edildiğinde uygulanır.

3. Yamayı doğrudan mı uygularsınız, önce test mi? Nerede test mi?

   Asla doğrudan canlı üretim ortamına uygulanmaz. Yama, fabrikadaki aktif makineye kurulmadan önce üreticinin (Baykal) simülasyon ortamında veya fabrikadaki **Test/Laboratuvar Tezgâhında** eksiksiz olarak test edilir. Büküm eksenlerinin (X, Y, Z) toleranslarının ve PLC döngü sürelerinin kararlılığı doğrulanmadan canlı sisteme geçilmez.

4. Bu yama bir safety validation etkiliyor mu? Nasıl anlarsınız?

   Evet, PLC firmware kütüphanesinin güncellenmesi emniyet sistemiyle olan dijital köprüyü etkileyebilir. Bunu anlamak için yama sonrasında Safety PLC ile Normal PLC arasındaki haberleşme bütünlüğü test edilir, SIL/PL standartlarına uygunluk testleri (Functional Safety Verification) yeniden koşturulur ve ışık bariyeri tepki süreleri hassas ölçüm cihazlarıyla doğrulanır.

5 Yama mümkün değilse compensating control (telafi edici önlem) ne olur?

Yamanın hemen uygulanamadığı veya sistem kararsızlığı yarattığı durumlarda alınacak telafi edici önlemler şunlardır:

- CNC kontrol ünitesi ile dış ağ/ERP arasındaki bağlantı geçici olarak kesilir (Ağ izolasyonu).
- Uzak erişim portları kapatılır; yalnızca yerel mühendislik istasyonundan fiziksel kablo ile kontrollü erişime izin verilir.
- Güvenlik duvarı (Firewall) kuralları sıkılaştırılarak zafiyetli porta gelen anormal paketler engellenir.

Bu föyün çıktısı **Vulnerability Decision** → Evidence Pack **EP 09 · 10 · 11** başlığına oturur.

LABORATUVAR 6 · PAKETPRO 3000 · Paketleme Makinesi

CRA Incident Simulation

Çıktı: Incident Workflow

Ad Soyad Mustafa Önler | Grup Gece-B | Tarih

Senaryo: Saat 10:15. Baykal Abkant Pres'in servis hesabına gece 03:00'te tanınmayan bir konumdan girilmiş. PLC konfigürasyonu değişmiş olabilir; lazer koruma (ışık perdesi) parametreleri henüz doğrulanmadı. Makine çalışıyor. Vardiya sorumlusu sizsiniz.

Kavram: Bir olayda en değerli iki şey **zaman** ve **kanıt**tır. CRA'nın 24s / 72s / 14 gün yükümlülükleri, iyi bir müdahale akışının doğal kilometre taşlarıdır — ezber değil.

Görev — zaman çizgisini doldurun

1. **10:15 — ilk 15 dk:** Kimi ararsınız? İlk üç eyleminiz?

- **Arama:** Derhal Fabrika Üretim Müdürünü ve IT/Siber Güvenlik birimini (SOC) ararım.
- **Eylem 1:** Operatöre acil talimat vererek **makineyi güvenli duruma (Safe State) geçiririm** (Acil stop butonuna basarak hidrolik üst çeneyi kilitlerim ve makinenin enerjisini keserim).
- **Eylem 2:** Makinenin CNC kontrol ünitesi ve uzak bakım modülünün fabrika ağı ve internet ile olan **fiziksel/ağ bağlantısını anında keserim** (izolasyon).
- **Eylem 3:** Makineyi resetlemem veya kapatmam; adli bilişim (forensics) için logların silinmemesi adına mevcut haliyle bırakırım ve güvenlik şeridi çekerim.

2. **İlk 2 saat:** Egzoz güvende mi — nasıl doğrularsınız? Hangi kanıt korunur? Hangi hesap kapatılır?

- **Emniyet Doğrulaması:** Yetkili teknisyenle birlikte Safety PLC parametrelerini ve ışık bariyerinin muting (körleme) hassasiyetlerini çevrimdışı (offline) bir terminalden okuyarak değiştirilip değiştirilmediğini doğrularım.
- **Korunan Kanıt:** CNC işletim sisteminin, uzak bakım modülünün ve PLC'nin gece 03:00'e ait **güvenlik ve olay loglarını (Event Logs)**, ağ trafik kayıtlarını (pcap) ve bellek (RAM) imajlarını kopyalayarak koruma altına alırım.
- **Kapatılan Hesap:** Gece giriş yapılan şüpheli "servis hesabı" ve VPN/uzak erişim portları derhal devre dışı bırakılır.

3. **24 saat — CRA erken uyarı:** Hangi bilgi hazır olmalı?

Cyber Resilience Act (CRA) kapsamında 24 saat içinde yetkili kurumlara (CSIRT/ENISA) sunulması gereken **Erken Uyarı Bildirimi (Early Warning)** için şu bilgiler hazır olmalıdır: Saldırının gerçekleştiği cihaz (Baykal APHS), tespit edilen ihlalin türü (yetkisiz erişim/parametre değişimi ihtimali), olayın tespit saati ve şu anki durumu (makine izole edildi, üretim durduruldu).

4. **72 saat — CRA bildirim:** Kök neden, etki, önlem — kim ne yapıyor?

- **Kök Neden:** Açık bırakılan uzak bakım portu ve sızdırılan yetkili servis parolası üzerinden ağa girilmesi.
- **Etki:** Üretim hattında X saat duruş ve potansiyel (gerçekleşmeden engellenen) S=3 seviyesinde ölümcül ezilme tehlikesi.
- **Önlem:** Parolaların sıfırlanması, MFA (Çok Faktörlü Doğrulama) kurulumu ve Jump Server izolasyonu.
- **Kim Ne Yapıyor?:** IT/Siber Güvenlik birimi bu detaylı teknik ve adli bilişim raporunu hazırlayarak CRA gereği yetkili kurumlara **Olay Bildirimi (Incident Notification)** sunar.

5. **14 gün — son rapor:** Hangi loglar/kayıtlar korunmuş olmalı?

Kapanış raporu için saldırının başladığı andan itibaren korunan şu kayıtlar sunulmalıdır: Ağ güvenlik duvarı (Firewall) erişim logları, CNC ve Safety PLC parametre değişiklik logları, VPN/MFA kimlik doğrulama kayıtları, sistem olay görüntüleyici (Event Viewer) kayıtları ve adli imajlar zinciri.

En sık hata: "Resetleyip devam edelim" — o düğme, kanıtı sonsuza dek siler. Önce emniyet, hemen sonra kanıt.

Bu föyün çıktısı **Incident Workflow** → Evidence Pack **EP 13 Incident Response** başlığına oturur.

LABORATUVAR 7 · PAKETPRO 3000 · Paketleme Makinesi

AI Safety Challenge

Çıktı: AI Fail-Safe Decision

Ad Soyad Mustafa Önler | Grup Gece-B | Tarih

> Kavram — Prediction ≠ Safety: Yapay zekâ bir karar üretir; güvenliği garanti eden mimari YZ'nin **dışında** tanımlanmalıdır. (Araçlar: fail-safe, human override, monitoring, confidence threshold, fallback).

Senaryo Uyarlaması: Baykal Abkant Pres makinesine büküm alanını izleyen, sac yerleşimini ve operatörün elini tanıyan "YZ Destekli Akıllı Kamera" eklenmesi planlanıyor.

Kamera → YZ Modeli (El mi/Sac mı?) → OK / STOP → Pres İniş İzni → Üst Çene Hızı

Görev — üç başarısızlıkta güvenli davranış

1. **Model yanlış sınıflandırdı:** Kusurlu parçaya OK verdi. (YZ, operatörün elini "sac levha" zannedip üst çenenin inmesine OK verdi). Sistem ne yapmalı? İkinci kontrol / insan onayı var mı?

   Cevap: YZ'nin kararı hiçbir zaman donanımsal emniyetin yerini alamaz. YZ modeli yanlışlıkla "OK" onayı verse bile, makinenin asıl güvenlik katmanı olan **fiziksel ışık bariyeri (lazer koruma)** eli algıladığı an Safety PLC devreye girip YZ'nin kararını ezmeli ve hidrolik valfleri kesmelidir (STO). Ayrıca nihai büküm onayı her zaman operatörün ayak pedalına basmasına (insan onayı) bağlı olmalıdır.

2. **Girdi manipüle edildi:** Kamera verisi bozuk/sahte. (Kamera lensi yağlandı, üzeri kapatıldı veya sensöre lazer tutuldu). Nasıl fark edilir? Şüpheli girdide ne yapılır?

   Cevap: Kameradan gelen görüntüde ani kararma, kontrast kaybı (entropy değişimi) veya sinyal donması "monitoring" (izleme) sistemiyle tespit edilir. Şüpheli bir girdi (veya siber müdahale kaynaklı sahte frame) algılandığında sistem anında "Safe State" (güvenli durum) moduna geçerek üst çeneyi kilitler. Üretime devam edebilmek için operatörün merceği temizleyip makineyi fiziksel olarak resetlemesi (fallback) gerekir.

3. **Confidence düştü:** Model "emin değilim" diyor. Eşik ne olmalı? Altında: dur / insana sor / fallback?

   Cevap: Ölümcül ezilme riski taşıyan bir abkant preste emniyet söz konusu olduğunda güven eşiği (Confidence Threshold) %99.9 olmalıdır. Model, kalıptaki cismin sac mı yoksa el mi olduğundan tam emin olamazsa (örneğin %85 eminse), makine hidrolik hareketi anında **durdurur**. HMI (CNC ekranı) üzerinde "Tanımsız Cisim Uyarı" pop-up'ı çıkar ve sistem **insana sor** (human in the loop) moduna geçer. Operatör görsel olarak alanı kontrol edip çift el butonuyla onay verene kadar makine kilitli kalır.

Karar tablosu — AI Fail-Safe Decision

Başarısızlık	Tanımladığınız güvenli davranış (hangi kavramla?)
Model yanlış sınıflandırdı	YZ kararını ezen fiziksel lazer bariyerin (Safety PLC) makineyi anında durdurması. **(Kavram: Fail-Safe & Human Override)**
Girdi manipüle edildi	Görüntü anomalisi/veri kaybı algılandığı anda üst çenenin hidrolik kilitlenmesi. **(Kavram: Monitoring & Fallback)**
Confidence düştü	Eşik (%99.9) altına düşüldüğünde makinenin durup CNC ekranından operatör onayı beklemesi. **(Kavram: Confidence Threshold & Human in the Loop)**

Bu föyün çıktısı **AI Fail-Safe Decision** → Evidence Pack **EP 03 + EP 15** başlığına oturur.